Nadel · payment accounting for garden cooperatives

Platform owner's manual

How the platform is built and how to run it: components, running it locally, Keycloak, creating cooperatives and users, the platform operator, every screen and button of the cooperative admin, data security, server deployment, development, common problems.

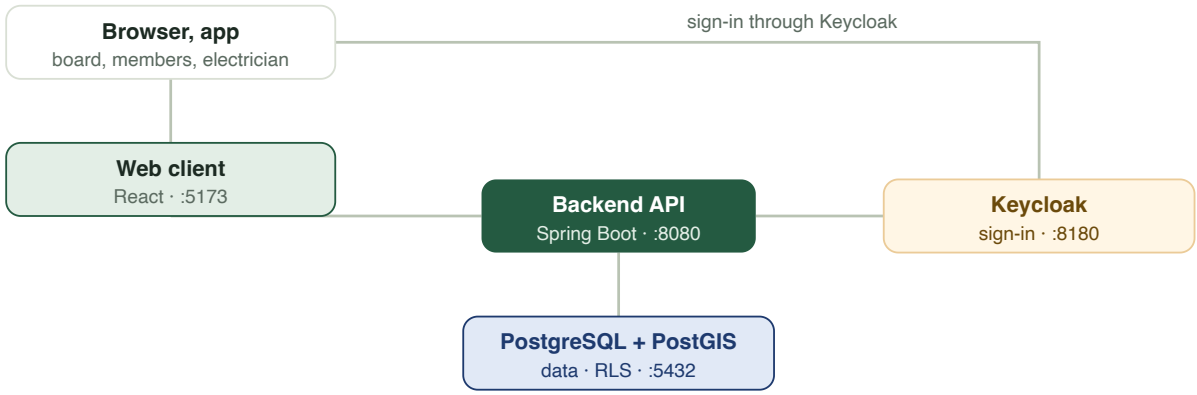
Reader	The platform owner and administrator
State	Chapters marked "works" describe the system as it is; "planned" — decided but not built yet
Edition	27 October 2026

Contents

1	How the platform is built	works
2	Local environment	works
3	Keycloak: sign-in and accounts	works
4	Cooperatives: creation and isolation	works
5	The platform operator	partly
6	Cooperative admin: screens and buttons	works
7	Permissions and roles	works
8	Data, security, personal data	works
9	Server deployment	planned
10	Updates and database migrations	works
11	How the system is developed	works
12	Common problems and fixes	works
13	Decision log	

1 How the platform is built

One platform serves many cooperatives. Each cooperative's data is kept apart by the database itself.



Platform components and local ports

Web client	The board's screens and the member's account. It calculates nothing; it shows what the server returns.
Backend	One application (a modular monolith) with the modules `tenancy` (cooperatives), `identity` (sign-in and permissions), `members`, `plots`, `settings`, `imports`, `tariffs`, `meters`, `money`, `audit`. A test guards the module boundaries.
API contract	`api/openapi.yaml` is the single source of truth: the server interfaces and the web and app client are generated from it.
PostgreSQL	All data. Every table with cooperative data has a `tenant_id` and an RLS policy: a query only sees its own cooperative's rows.
Keycloak	Accounts, passwords, sign-in. Cooperative roles are not kept in Keycloak but in the database; Keycloak holds only the platform operator role.
Mobile app	An Expo shell exists; the real app is phase 5.

How a request flows

1. A person signs in through Keycloak and gets a token with the `tenant_id` attribute (their cooperative).
2. The backend checks the token, finds the member by email and takes their permissions from the database.
3. For the request the database receives the `tenant_id`; RLS lets through only that cooperative's rows.

4. Board changes are published as events; the audit module records them through an "outbox", so no event is lost even if the server restarts.

2 Local environment

What the computer needs

Docker Desktop, JDK 25, Node.js 22 and pnpm, Git, the GitHub CLI (`gh`). Repository: `~/IdeaProjects/nadel-platform`.

First run

```
make install        # web and shared package dependencies
make up             # database, Keycloak, backend and web in one terminal (Ctrl+C stops
backend and web)
make e2e-install    # once: the browser for end-to-end tests
```

Make commands

Command	What it does
`make help`	Lists every command
`make install`	Installs client dependencies (pnpm)
`make infra`	Starts PostgreSQL + PostGIS and Keycloak in Docker and waits until ready
`make up` / `make dev`	Infrastructure + backend (:8080) + web (:5173); creates `infra/.env` with a local master key the first time
`make backend`, `make web`, `make mobile`	The backend, the web or the Expo server alone
`make down`	Stops the Docker containers (data is kept)
`make gen`	Regenerates the API client from `api/openapi.yaml`
`make test`	Backend tests (with a database container) and client tests
`make check`	Everything CI checks: contract, formatting, lint, tests
`make e2e`	End-to-end browser scenarios (Playwright) on a separate database
`make guide-shots`, `make guide`	Screenshots for the guides (from the running app) and the PDF build
`make clean`	Removes build output

Addresses and passwords (local development only)

What	Address	Sign-in
The app	`http://localhost:5173`	demo users below
API	`http://localhost:8080/api/v1`	a Keycloak token
Keycloak admin console	`http://localhost:8180/admin/`	realm master, `admin` / `admin`
PostgreSQL	`localhost:5432`, database `nadel`	`postgres` / `postgres` (superuser), `nadel_owner`, `nadel_app`

Demo users (password `nadel`)

Email	Who
`chairman@demo.local`	Chairman of CT «Надія»
`treasurer@demo.local`	Treasurer
`electrician@demo.local`	A member with the custom role "Електрик"
`member@demo.local`	A member
`member@other.local`	A member of another cooperative (CT «Світанок»), to check isolation
`operator@nadel.local`	The platform operator (no access to cooperative data)

The local master key (`infra/.env`)

Members' contacts are stored encrypted (chapter 8). The first time `make up`, `make backend` or `make e2e` runs, it creates the file `infra/.env` with one line, `NADEL_PD_MASTER_KEY=…`, a random local key. The file is git-ignored, has mode 600 and is read only by the backend process. An existing file is never overwritten.

- Never commit this file and never paste the key into a chat or a ticket.
- If you delete it, the contacts already in the local database become unreadable (the backend refuses to start with `PD_MASTER_KEY_MISMATCH`, chapter 12). Then reset the local database too (below) — it is only demo data.

Resetting the local database

```
make down && docker compose -f infra/docker-compose.yml down -v && make up
```

Erases all local data; migrations and demo data load again and Keycloak imports the realm again. Needed after changing `infra/keycloak/nadel-realm.json` or when test data has spoiled the demo.

PostGIS image on a Mac with Apple Silicon

The default image `postgis/postgis:17-3.5` exists only for Intel (linux/amd64); on an M-series Mac Docker runs it emulated, and the database, the backend tests included, is several times slower. Both the local stack and the backend tests (Testcontainers) take the image from the environment variable `NADEL_POSTGIS_IMAGE`. On a Mac put the multi-architecture build of the same PostgreSQL 17 + PostGIS 3.5 into the shell profile (`~/.zshrc`):

```
export NADEL_POSTGIS_IMAGE=imresamu/postgis:17-3.5
```

It is built by a maintainer of the official PostGIS images from the same sources. After switching, reset the local database once (above): a data volume is not moved between processor architectures. CI and servers keep the default image.

3 Keycloak: sign-in and accounts

Keycloak keeps accounts and passwords. The platform's realm is `nadel` with two clients, `nadel-web` and `nadel-mobile`. Sign-in is by email, self sign-up is off, password reset by email is allowed (it works once mail is configured), the sign-in page speaks Ukrainian (default) and English.

How an account is tied to a cooperative

- The user attribute `tenant_id` is the cooperative's identifier. It goes into the token, and the backend works only with that cooperative's data.
- The member is found by **email**: the email in Keycloak must match the email on the member card (any letter case). The backend remembers the link at the first sign-in. The first chairman of a new cooperative is linked differently, by the Keycloak user's identifier (chapter 4).
- Roles and permissions live in the cooperative's database, not in Keycloak. The exception is the `PLATFORM_OPERATOR` role.

Creating an account for a member

1. Make sure the member exists in the system and their card has an email (the chairman does this).
2. Keycloak admin console → choose the realm **nadel** at the top left → **Users** → **Add user**.
3. Username and Email — the same address; First name, Last name; switch on **Email verified**; **Create**.
4. Tab **Attributes**: key `tenant_id`, value — the cooperative's identifier (chapter 4) → **Save**.
5. Tab **Credentials** → **Set password**: a temporary password with **Temporary** on — the person sets their own at the first sign-in.

> **NO ATTRIBUTES TAB?**
>
> Keycloak 26 hides custom attributes by default. Once: **Realm settings** → **General** → **Unmanaged attributes** → "Admin can edit" → **Save**.

Other tasks

Task	Where
Reset a password	Users → user → Credentials → Reset password (Temporary)
Block sign-in	Users → user → switch off **Enabled**. Archiving the member in the system also blocks sign-in.
End all sessions	Users → user → Sessions → Sign out

Task	Where
Make someone the platform operator	Users → user → Role mapping → Assign role → `PLATFORM_OPERATOR`; no `tenant_id` attribute
Change realm settings for good	Edit `infra/keycloak/nadel-realm.json` and reset the local database (chapter 2): the file is imported only into an empty Keycloak

Creating accounts and email invitations from the cooperative admin come with the operator console and mail (phases 4 and 7). Until then the platform owner creates accounts in Keycloak.

4 Cooperatives: creation and isolation

A cooperative (a *tenant* in the code) is a row in the `tenant` table with an identifier (UUID) and a name. When a cooperative is created the system gives it the base roles, the settings and the standard charge types.

Creating a new cooperative (until the operator console exists)

Contacts (phones, email, address) are encrypted by the application, so SQL cannot write them. The first chairman is therefore created *without* contacts and is linked to the Keycloak account by the account's identifier; the chairman enters the email and phones in the app afterwards.

1. Connect to the database as the superuser: `docker compose -f infra/docker-compose.yml exec postgres psql -U postgres -d nadel`.
2. Create the cooperative, with the name filled in, and note the identifier from the message:

```
DO $$
DECLARE t uuid := gen_random_uuid();
BEGIN
  INSERT INTO tenant (id, name) VALUES (t, 'СТ «Назва»');
  PERFORM seed_base_roles(t);          -- roles, settings, charge types
  RAISE NOTICE 'tenant_id = %', t;
END $$;
```

1. Create the chairman's account in Keycloak with the attribute `tenant_id` set to that identifier (chapter 3). Open the new user and copy the **ID** shown on the **Details** tab (a UUID) — it is the Keycloak *subject*.
2. Back in `psql`, add the chairman with the identifier and the subject (name and both values filled in):

```
DO $$
DECLARE t uuid := '<tenant_id>'; m uuid := gen_random_uuid();
BEGIN
  INSERT INTO member (id, tenant_id, last_name, first_name, delivery_channel,
keycloak_subject)
  VALUES (m, t, 'Last name', 'First name', 'PAPER', '<Keycloak user ID>');
  INSERT INTO member_role (tenant_id, member_id, role_id)
  SELECT t, m, id FROM role WHERE tenant_id = t AND base_code = 'CHAIRMAN';
END $$;
```

1. The chairman signs in (the subject links the account to the card) and opens "Members" → their own card → "Edit" to enter the email, phones and the preferred channel; the app encrypts them. Then the Excel import, members, tariffs and meters.

The cooperative's encryption keys are created by the server the first time the cooperative needs them (for example when the chairman saves the first contact); there is nothing to do for them here. The delivery channel stays "Paper" until a contact exists, because the database rejects a channel without its contact.

> **A TEMPORARY WAY**
>
> This SQL is a workaround until the operator console; creation through it is not in the audit log. On the server a "first cooperative" command replaces it (chapter 9), later the operator console.

Isolation

- The application talks to the database as `nadel_app`, which cannot bypass RLS; migrations run as `nadel_owner`.
- Every new table has an isolation test: another cooperative's data is invisible even to a direct query.
- Deleting a cooperative is not provided; the data stays until an archiving decision (phase 7).

5 The platform operator partly

The operator is the person who runs the platform (you). The principle (ADR 0008): **the operator does not see cooperative data** — no members, no plots, no money.

What	State
Signing in as `operator@nadel.local`: the app says "No cooperative", data is unavailable	works
Operator console: list of cooperatives, creating a cooperative and its chairman, blocking	phase 7
Platform reports without personal data: number of cooperatives, plots, active users, storage used, subscription state	phase 7
Support access: a chairman grants temporary access to their cooperative; every action goes to their audit log	phase 7
Subscriptions and payment for using the platform	phase 7

Until then the operator's technical tasks are Keycloak (chapter 3), creating cooperatives (chapter 4), the server and backups (chapter 9).

6 Cooperative admin: screens and buttons

Every screen, every button — what it does and which permission it needs. A person does not see buttons they have no permission for; the server refuses such a request anyway.

Header and menu

Element	What it does	Permission
Cooperative name	Goes to the home page	—
УКР / ENG	Interface language, remembered in the browser	—
System / Light / Dark	Theme	—
Sign out	Ends the session	—
Menu	Shows only the sections the person has permissions for	—

Plots

Element	What it does	Permission
Search, "Kind", "Status", "Show archived"	Filter the register	View plots (a member sees a short list)
Add plot	Form: number, street, kind, area (sotkas or m²), cadastral number, building, notes	Edit plots
Card → Edit	Changes the plot's data	Edit plots
Card → Archive / Restore	Hides the plot from the list or brings it back. Refused while the plot has a lasting water connection (or an active meter): end the connection on the plot card first. The same applies to turning a plot into common land	Edit plots
Card → Delete	Only for a plot that never had an owner	Edit plots
Card → Change owner	Date, new owners with shares (sum = 1), basis; "Add member" right in the form	Edit ownership
Card → Correct (next to a record)	Fixes dates, share or person in an ownership record, with a reason	Edit ownership
Card → Tariffs (month)	What the plot will be charged for the chosen month	View tariffs, or own plot

Element	What it does	Permission
Card → Meters	The plot's meters with history and replacement chain	View meters, or own plot

Members

Element	What it does	Permission
Search, "Show archived"	By any part of the name; by the full phone in any usual form or exactly its last 4 digits; by the whole email. A part of an email or digits from the middle of a phone find nothing	View members
Add member	Name, phones, email, address, preferred channel, Telegram, Viber, notes	Edit members
Card → Edit	Changes the member's data	Edit members
Card → Archive / Restore	Blocks or restores sign-in; not for a plot owner or the last chairman	Edit members
Card → Change roles	Assigns roles to the member	Manage roles
Card → Change history	The audit log of this member	View audit log

Roles

Element	What it does	Permission
Add role	Name, description, set of permissions	Manage roles
Edit	Changes name, description, permissions (the chairman's permissions never change)	Manage roles
Restore standard name / description	Undoes the renaming of a base role	Manage roles
Delete	Only a custom role assigned to nobody	Manage roles

Cooperative settings

Element	What it does	Permission
Who sees plot colours	"Own plots only" or "All plots"	Manage settings
Meter tree	Opens the tree (below)	View meters
Tree → From / To	A range: every meter shows consumption, "calculated" or "no reading after …"	View meters
Tree → Move	A new parent meter (or "outside the tree") from the date in "Effective from"	Manage meters

Import

Element	What it does	Permission
Download template	The Excel template in the interface language	Run import
Choose file → Check file	Checks without saving: new, updated, unchanged, problems by sheet, row and column	Run import
Import	Saves everything at once (only with no problems, within 30 minutes)	Run import
Import history	Who, when, which file, how many records	Run import

Tariffs

Element	What it does	Permission
Charge types → Add / Change	Name, description, "Active" (an inactive type gives no amounts)	Manage tariffs
Charge types → Up / Down	Order; it also sets the payment allocation priority within one debt date	Manage tariffs
Charge types → Archive	Removes the type and its tariffs	Manage tariffs
New tariff	Charge type, name, first version: valid from, basis, frequency, rate, due date, note	Manage tariffs
Card → New version	A new rate from a date; a past date shows a recalculation warning	Manage tariffs
Card → Edit / Delete a version	Only while no charge uses it; the only version cannot be deleted	Manage tariffs

Element	What it does	Permission
Card → Plots → Change	"All plots" with exclusions (with a reason) or "Selected plots"	Manage tariffs

Meters

Element	What it does	Permission
Filters, "Show removed meters"	Resource, kind, street	View meters
Register a meter	Kind, resource, plot or name, serial number, installation date, initial reading	Manage meters
Card → Edit	Serial number, name, note	Manage meters
Card → Replace meter	Date, old final reading, new serial and initial reading; "Fill in as a wrap-around"	Manage meters
Card → Remove	Removal date and final reading	Manage meters
Card → Delete	Only a meter without readings	Manage meters
Card → readings → Correct / Delete reading	While the reading is not used in a charge	Enter readings

Readings and approvals

Element	What it does	Permission
Round date	The date for all readings of the round; defaults to today, with a hint	Enter readings
Resource, Street, "No reading since"	Round filters; the resource is remembered	Enter readings
Meter row → Save	Saves the reading (the row's date can be changed); shows consumption and warnings at once	Enter readings
To approve → Approve	A member's reading becomes counted	Approve readings
To approve → Reject	With a reason the owner sees	Approve readings
View charges	yes	yes

Element	What it does	Permission		
Run charges	yes	—	—	—
Reverse charges	yes	—	—	—
Close periods	yes	—	—	—
Recalculate charges	yes	—	—	—

Charges

Element	What it does	Permission
Charges → Months → month	Totals, the check list, history of the month	View charges
Month → Charge the month	Preview, then "Book"	Run charges
Month → Close the month	Confirms with the check list; only the earliest open month	Close periods
Not charged → Retry	Retries one item	Run charges
Charges → Recalculations	The log of booked recalculations; "Open" shows the lines, the amounts and the reversals and adjustments created	View charges
Recalculations → New recalculation → From month, To month, types, plots, Preview	Shows what would change; nothing is written	Recalculate charges
Preview → Reason → Book the recalculation	Books exactly this preview; the reason is required	Recalculate charges
Tariff card → Edit / Delete a used version	A preview step with a reason; the change and the recalculation are saved together	Manage tariffs and Recalculate charges
Meter card → Correct / Delete a charged reading	A preview step with a reason; without the permission: "The reading has already been charged — ask the chairman"	Enter readings and Recalculate charges
Plot account → Adjustments only	Filter of the adjustments of closed months, with links to the original charge and the recalculation	View charges (or own plot)
Losses / Common consumers → From, To, Preview, Book	A range run: preview, then booking of exactly that preview	Run charges
Past runs → Details, Reverse the run	The lines of a run; reversal with a reason	View charges / Reverse charges

Element	What it does	Permission
Plot card → Account → Details	The calculation of a charge	View charges (or own plot)
Account → Reverse	A reversal with a reason (not offered in a closed month)	Reverse charges
Account → Enter an opening balance	Charge type, amount, date, reason	Run charges
Plot card → Water → Connect / Disconnect	A water connection with its dates	Manage meters
Settings → red threshold, Losses, Common consumers, Water supply	Thresholds, losses mode, splits, bulk water connections	Manage settings / Manage meters

KNOWN GAPS

- The lasting connections of a removed well can only be ended on each plot's card.

Payments and cash desk

Element	What it does	Permission
Payments (menu) → list	Payments, newest first: receipt or bank document, date, plot, payer, source, amount, "Allocated", "Prepayment", a "Reversed" mark. Filters: "From", "To", "Source", "Plot", "Billing month"	View payments
Payments → Enter payment	Opens the payment form	Enter payments
Plot card → Enter payment	The same form with the plot already chosen	Enter payments
Form → Plot, Source (Cash / Bank), Date received, Amount	The date is not later than today; a date other than today only shows a gentle warning; the amount is above zero with at most two decimals. Common land and an archived plot take no payments	Enter payments
Form → Payer, Payer note, Bank document number	The payer is optional (the plot's owners first); the note, up to 200 characters, is stored encrypted; the document number, up to 64 characters, is for bank payments only	Enter payments

Element	What it does	Permission
Form → allocation table (Allocate, Add a charge, Prepayment)	The proposal: the oldest debt first, and within one debt date the order of charge types. A line's amount can be changed or another open charge added; with automatic allocation on, the free remainder goes at once to the oldest debts (a note under the "Prepayment" line says "The remainder will be placed automatically on the oldest debts"), otherwise it is the "Prepayment". The table stays on screen: a message at a wrong line and "Allocated X of Y" below	Enter payments
Form → Several plots of one payer	Split mode: the payer, their current plots with debts and the parts of the payment (by default in proportion to the debts); the parts must add up to the payment amount	Enter payments
Form → Save	For cash shows "Receipt № ..." large; "Another payment", "Open the payment card". If the data changed after the preview, "The data changed after the preview" and nothing is saved	Enter payments
Payment card	The payment's details, "Currently allocated" (the current allocation: charge, period, amount; "Allocated from prepayment" for automatic ones), "Allocation history" (allocations and "Taken back from the charge" with the cause and the author), the other parts of the group, who entered it and when; "Allocate prepayment" when the prepayment is above 0.00, a charge is open and automatic allocation is off; the payer note is shown only to someone who also has "View members"	View payments
Payment card → Reallocate	Shows the current allocation and a new proposal; saving takes back the old allocation and writes the new one in one step; written to the audit log. Lines left at 0.00 create no prepayment while open debts exist (automatic allocation on)	Enter payments
Payment card → Reverse	Needs a reason (up to 500 characters); takes back every allocation of the payment, so the debts return. A payment is reversed once; a part of a group on its own; the receipt number stays and the payment is marked "Reversed"	Reverse payments
Plot account → payments, "Payments only"	Payments, their reversals and "Allocated from prepayment" interleaved with the charges by date; per charge: charged, paid, open; the debt after payments, with "Prepayment X" next to the total debt when the prepayment is above 0.00; "Payments only" keeps only the payments	View charges (payments: also View payments or an own plot)
Plot account → Prepayment → Allocate prepayment	Shown (also on the payment card) when the prepayment is above 0.00, a charge is open and "Allocate prepayment automatically" is off: a proposal over the open charges, which can be changed	Enter payments

Element	What it does	Permission
Settings → Allocate prepayment automatically → Save the payment settings	On by default: prepayment never waits while the plot has open debts - the remainder of a payment is placed at once - and later goes by itself to the plot's new charges and to released amounts. Without the permission the switch is read-only. Switching it on does not allocate old prepayment at once	Manage settings
Charges → Months → "Received"	Next to "Charged": what came in during the month (payments net of reversals)	View charges
Reports → "Payments"	Payments by billing months or receipt dates; filters: source, street; totals per source; the payer note only for someone who also has "View members". The "Plot balances", "Debtors" and "Charges by month" reports now take payments into account	View reports + View payments
My account → My charges	A member sees payments of their own plots only: date, receipt number, amount, what it paid, the prepayment and the debt after payments; never the note or who entered the payment	own plot

Reports

Element	What it does	Permission
Reports (menu) → a report card	Opens one of the nine reports; "Debtors" is there only with "View members"	View reports
Report → filters, "Show"	Refreshes the preview (first 200 rows and totals); under the filters it says what the period counts by	View reports
Report → "Download Excel"	A file with all rows in the interface language; more than 20 000 rows on a sheet is refused; recorded in the audit log	View reports
Reports → "Report templates"	The templates page (below)	Manage report templates
Reports → "Generate" next to a template	The "Generate a file" window: "From", "To" (up to a year), "Generate and download"; the file is not stored	View reports
Templates → "Tax report" → "Upload the template"	A fixed slot; until it is uploaded the status is "The template is not added yet"	Manage report templates
Templates → "Add a template"	A name, a description, an .xlsx file up to 2 MB; refuses macros, damaged and oversize files	Manage report templates

Element	What it does	Permission
Template → "Upload new version", "Versions" → "Download"	The new version becomes current; older versions stay available	Manage report templates
Template → "Archive"	The template becomes read-only, its name is freed, its versions can be downloaded	Manage report templates
Templates → "Placeholders" (search, "Copy")	The catalogue of every placeholder: type, description, example	Manage report templates
Settings → "Requisites" → "Save the requisites"	Official name, legal address, bank, IBAN (validated); the EDRPOU code is read-only; recorded in the audit log	Manage settings

DEMO DATA

The sample template "Відомість земельного податку" (Land tax statement) and the made-up requisites (EDRPOU, address, IBAN) exist only in the demo data of the local profile (`demoledger=on`), so that "Generate" works at once. The "Tax report" slot is left empty in the demo on purpose. None of this is present in tests or on a server.

Audit log and account

Element	What it does	Permission
Audit log → record type, From, To, "Only this record", "Only this author"	Filter entries; "Remove filter". Old and new values of phones, email, address, Telegram, Viber and notes are shown only to a person who also has "View members"; for anyone else the entry says the field changed and shows "hidden" in place of the values	View audit log (values: also View members)
My account	My details, roles, what I may do, my plots with shares, what I will be charged, my payments and prepayment	—
My meters → Submit a reading	A reading for the board to approve	own plot

7 Permissions and roles

Permission	Chairman	Treasurer	Member	Electrician (demo)
View members	yes	yes	—	—
Edit members	yes	—	—	—
Manage roles	yes	—	—	—
View audit log	yes	yes	—	—
View plots	yes	yes	—	—
Edit plots	yes	—	—	—
Edit ownership	yes	—	—	—
Run import	yes	—	—	—
Manage settings	yes	—	—	—
View tariffs	yes	yes	—	—
Manage tariffs	yes	—	—	—
View meters	yes	yes	—	yes
Manage meters	yes	—	—	—
Enter readings	yes	—	—	yes
Approve readings	yes	—	—	—
View reports	yes	yes	—	—
Manage report templates	yes	—	—	—
View payments	yes	yes	—	—
Enter payments	yes	yes	—	—
Reverse payments	yes	—	—	—

- The chairman always holds every permission, including any new one.
- The chairman changes the treasurer's and other roles' permissions in "Roles".
- A member without permissions sees only their own data — enforced by the server.
- Charges: "View charges" opens the Charges screens and every plot account (the treasurer has it, read-only); "Run charges" runs months, losses and common consumers, retries "Not charged"

and enters opening balances; "Reverse charges" reverses a charge or a run; "Close periods" closes a month; "Recalculate charges" (the chairman only) recalculates past charges and books corrections of used tariff versions and readings. A member without "View charges" sees only their own accounts.

- Reports: "View reports" (chairman, treasurer) opens the nine reports, downloads, and generates files from templates; the "Debtors" report also needs "View members". "Manage report templates" (the chairman only) uploads, replaces, downloads and archives templates, including the tax report slot. A member and the electrician have no reports by default; the chairman gives these permissions to a custom role in "Roles".
- Payments: "View payments" (chairman, treasurer) opens "Payments", the cards, the allocation and the "Payments" report; "Enter payments" (chairman, treasurer) enters payments, splits them over plots, reallocates and allocates prepayment; "Reverse payments" (the chairman only) reverses a payment - a treasurer who made a mistake asks the chairman. The "Allocate prepayment automatically" switch needs "Manage settings". A member sees the payments of their own plots in "My charges"; the electrician sees none.

8 Data, security, personal data

Isolation	Database RLS on every table with cooperative data; the application cannot bypass it.
Access	The server checks permissions on every request; a member sees only their own plots.
Audit log	Who, when, what changed, old and new value. Entries are never changed or deleted.
Not stored	Tax numbers (РНОКПП), passport data, dates of birth — there are no such fields.
Server logs	No personal data: even a database error message does not include values.
Events	Completed events are deleted from the event table at once, because they may carry personal data.
Secrets	Only from environment variables; the repository holds only local development passwords. CI scans for leaked secrets (gitleaks).
Report templates are data	The system **never executes** formulas or code from a template: placeholders are substituted, formulas are left alone, and Excel recalculates them in the opened file. Macros (`.xlsm`), active content, OLE objects and external links never reach storage (links are removed with a warning). Only `.xlsx` up to 2 MB is accepted; the zip-bomb guard (limits on the unpacked size and the compression ratio) and the XXE guard (XML without DTDs or external entities) apply both at upload and at every generation. Templates and versions are tables with `tenant_id`, RLS and isolation between cooperatives; generated files are not stored.
Reports and personal data	Personal data (names, phones, e-mails) is only in the "Debtors" report, which also needs "View members"; templates have none. The platform operator sees neither reports nor cooperative data. The audit log has the actions `REPORT_GENERATED` (the report or the template with its version, the filters, the row count — never the content), `REPORT_TEMPLATE_UPLOADED` and `REPORT_TEMPLATE_ARCHIVED`; a change of requisites is recorded with the changed fields.
Dependencies	CI checks known vulnerabilities (pnpm audit, OSV) and the code (Semgrep).
Encrypted contacts	Phones, email, postal address, Telegram, Viber and the notes of a member are stored encrypted (AES-256-GCM), also in the audit log and in the pending Excel import. Names stay readable, because the board searches and sorts by them. A copy of the database without the master key reveals no contact. On the server the disk and the backups are encrypted as well (chapter 9).

Personal data encryption: keys

- **Master key** `NADEL_PD_MASTER_KEY`: 32 random bytes in base64. It lives only in the server's environment — never in the database, the repository, the logs or a backup.
- **Cooperative keys**: every cooperative has its own data key (and a key for the search indexes), kept in the database *wrapped* by the master key. They are created the first time a cooperative needs them. So a stolen database holds only wrapped keys, and one cooperative's key never opens another's data.
- Search finds contacts without decrypting the table: the server compares keyed hashes of the full phone, its last 4 digits and the whole email (chapter 6, "Members").

Generating the master key

```
openssl rand -base64 32
```

Put the output into the server's secret store as `NADEL_PD_MASTER_KEY`. Use different keys for staging and production. The server in the `prod` profile **refuses to start** without a key or with one that is not 32 bytes of base64; the message names the setting `NADEL_PD_MASTER_KEY` and never shows a key. With a key that does not match the database it refuses too, with `PD_MASTER_KEY_MISMATCH` (chapter 12).

> **A LOST MASTER KEY = LOST CONTACTS**
>
> Nothing else can open the encrypted contacts: not a backup, not the developers. Keep at least two copies **offline** (a password manager entry and a sealed paper copy), apart from the database backups. A backup stored together with its key gives no protection, and a backup without the key cannot be restored to readable contacts. Names, plots, charges and payments are not affected — only the contacts, addresses and notes.

Rotating the master key

1. Generate a new key: `openssl rand -base64 32`.
2. Deploy with the new key as `NADEL_PD_MASTER_KEY` and the old one as `NADEL_PD_MASTER_KEY_PREVIOUS`.
3. At start-up the server re-wraps every cooperative's keys with the new key (one transaction per cooperative) and logs counts only, for example `Personal data keys: 12 checked, 12 re-wrapped, 0 left on the previous master key`. If a key is wrapped with neither master key, the start-up stops with `PD_MASTER_KEY_MISMATCH` before anything is changed.
4. Remove `NADEL_PD_MASTER_KEY_PREVIOUS` and deploy again.
5. Keep the old key offline until no backup made before the rotation is retained: such a backup still holds keys wrapped by the old key.

Only the master key is rotated; the cooperatives' own data keys stay as they are. Restore drills need the key: restore the database, start the backend with the key and check that contacts open.

9 Server deployment planned · 6a

The decision (ADR 0010): the whole product is finished locally first, the server comes last. The plan is as follows.

What runs on the server

- One virtual server in an EU data centre (initially Hetzner Cloud, Germany or Finland), about 4 vCPU and 8 GB RAM; a smaller second one for staging.
- Docker Compose: PostgreSQL + PostGIS, Keycloak in production mode, the backend and Caddy (the web client, HTTPS with automatic certificates). Only ports 80 and 443 are open to the outside.
- Cost: tens of euros per month.

How updates arrive

1. Every merge to `main`: GitHub builds the images, pushes them to the GitHub Container Registry and updates staging.
2. A version tag `v…`: deployment to production after your approval in GitHub, with a database backup right before.
3. Rollback: deploy the previous tag with a separate action.

First installation

- The server: SSH keys only, no root, a firewall, automatic security updates.
- A domain and DNS pointing to the server; secrets in the server's environment file and in GitHub environments; the backend refuses to start with a default password.
- A "first cooperative" command creates the cooperative, its chairman and the Keycloak account and sends the set-your-password email.
- The Keycloak admin console and the database only through an SSH tunnel.

Backups and monitoring

- Every night an encrypted copy of the application and Keycloak databases, stored outside the server; 30 daily and 12 monthly copies kept. Every month a copy is restored on staging as a test.
- An external uptime check with Telegram alerts; error tracking without personal data; disk, memory and certificate alerts.

A step-by-step runbook with exact commands joins this chapter with the deployment feature.

10 Updates and database migrations

- The database structure changes only through Flyway migrations (`backend/src/main/resources/db/migration`), run when the backend starts. Existing migrations are never edited — only new ones are added.
- "Expand, then contract": a release may add tables and fields; removing or renaming waits for the next release, when the old code no longer runs. The previous version thus works on the new database and a rollback is safe.
- Demo data (`db/demo`) loads only in the development profile; the server never has it.

11 How the system is developed

From an idea to main

1. **A feature document** in `docs/features/NNN-….md`: requirements, rules, worked examples, acceptance criteria. The number is the highest in `context/spec` + 1.
2. **The pipeline**: `/feature-pipeline docs/features/NNN-….md` in Claude Code. Agents write the specification, the plan, the code and the tests slice by slice; a separate reviewer checks every slice; at the end every criterion is verified, screenshots taken, the full suite run, a PR opened and its checks brought to green.
3. **Your check**: the app from the PR branch is running for you; try the scenarios from the report.
4. **Merging** — only you: `gh pr merge <number> --squash --delete-branch`, then `git switch main && git pull`.

CI checks on every PR

Check	What it does
Backend	Build, every test with a database container, module boundaries, coverage floor
Clients	API contract, formatting, types, tests, lint, web build
Security	Leaked secrets (gitleaks), dependency vulnerabilities (pnpm audit, OSV)
SAST	Static code analysis (Semgrep)
End-to-end	Browser scenarios on a freshly started database

Rules

- Agents never merge or approve PRs and never push to `main`; only the owner commits changes to `CLAUDE.md` and `.claude/`.
- Commits never mention AI. All repository text is English, except the guides in `docs/guide` (Ukrainian and English).
- Verification levels: a new feature runs the full suite locally; a small fix on an open PR runs only the affected tests, and CI runs the full suite.
- Models: the orchestrator and the reviewer use your Claude Code session's model (Opus); the worker agents use the model set in `.claude/agents`.
- Working notes outside git: `NOTES.local.md` (questions and answers) and `DECISIONS.local.md` (decisions and deferred tasks).

12 Common problems and fixes

Problem	Cause and fix
"Port 8080 was already in use", the web opened on 5174	A previous run is still going (for example the one the pipeline left for review). `lsof -ti :8080 -ti :5173 | xargs kill`, then `make up`.
"Account not linked"	The email in Keycloak differs from the member card's, or the member is archived, or Keycloak has no `tenant_id`.
`admin` cannot sign in to the Keycloak console	Use the **master** realm at `/admin/`, not nadel; check the keyboard layout.
"E2E ..." entries and odd plots in the audit log	Traces of old end-to-end tests. Reset the local database (chapter 2); the tests now use a separate database.
"platform (linux/amd64) does not match" for postgres	The default PostGIS image is Intel-only and runs emulated on a Mac — slower, tests included. Set `NADEL_POSTGIS_IMAGE` to the arm64 image (chapter 2) and reset the local database.
Slow backend tests, long CI	On a Mac first check `NADEL_POSTGIS_IMAGE` (chapter 2): under emulation the suite takes several times longer. The time of every test class is in `backend/target/surefire-reports`.
Git: "File exists ... .lock"	A lock file left by an interrupted command. Make sure no git is running and delete the named `.lock`.
The backend does not start: `PD_MASTER_KEY_MISMATCH` in the log	The server was started with a master key other than the one that wrapped the cooperatives' keys (a different environment's key, a lost or changed value). Start it with the right key. To change the master key on purpose, start with the new key as `NADEL_PD_MASTER_KEY` and the old one as `NADEL_PD_MASTER_KEY_PREVIOUS` (chapter 8, rotation). Locally: use the key in `infra/.env`, or, if that file was lost, reset the local database with `docker compose -f infra/docker-compose.yml down -v` (demo data only).
The backend does not start: `NADEL_PD_MASTER_KEY is missing or is not 32 bytes of base64`	The variable is not set or is malformed (extra characters, a truncated copy). Generate one with `openssl rand -base64 32`, or on a local run use `make up` / `make backend`, which create `infra/.env` (chapter 2). The same message names `NADEL_PD_MASTER_KEY_PREVIOUS` if that one is malformed.
Realm file changes did not apply	The realm is imported only into an empty Keycloak — reset the local database.
IntelliJ keeps asking for access to other apps' data	System Settings → Privacy & Security → Full Disk Access → IntelliJ IDEA, restart.

Problem	Cause and fix
A generated Excel file opens with a repair prompt	Tell the developer and attach the template and the generated file. The template filler is our own (ADR 0015); a repair message is one of the conditions for reconsidering it in favour of Apache POI.
The pipeline stopped	`/feature-pipeline resume` continues where it stopped, from its log.

13 Decision log

Date	Decision
17.10.2026	Design: the "calm registry" — side menu, tables, green accent.
18.10.2026	The chairman's answers: the chairman chooses how common consumers are split; the quarter report shows readings, cost and amount; a building is reference only; no meter, no charge; the chairman configures the meter tree.
18.10.2026	Other members' plot colours hidden by default; "All plots" only by a general meeting decision.
20.10.2026	The whole product on the local machine first, servers last.
21.10.2026	The interface always in one language. A rate has up to 4 decimals, shown without trailing zeros; amounts 2 decimals.
21.10.2026	A tariff version can be corrected or deleted until a charge uses it; then through recalculation.
21.10.2026	Readings are not tied to months: a reading is a value on a date; moves in the tree take effect from a date.
22.10.2026	A resource icon; a plot's two meters in one card; calculated consumption rounded for display.
22.10.2026	Electricity charged per reading; the chairman chooses the losses mode; negative losses are not charged; common consumers as a separate line.
22.10.2026	Water like electricity: an unconnected plot pays neither for water nor for the pump; any number of wells and quarters.
22.10.2026	Verification levels: small fixes run only the affected tests locally, the full suite in CI.
22.10.2026	Two guides in Ukrainian and English in `main`: for the board (working in the system and the calculation rules) and for the platform owner (this one).
27.10.2026	Reports introduce no new rules, and templates are data (ADR 0015): our own streaming OOXML filler instead of Apache POI (POI stays the recorded fallback; the engine is about 1900 lines against the threshold of 2000 that triggers a review), with no formula evaluation, no macros and no external links.
28.10.2026	Payments (015): allocation from the oldest debt, within one debt date by the order of charge types; prepayment goes automatically to new charges (a setting, on by default); cash gets an internal receipt with a running number, not a fiscal receipt; only the chairman reverses a payment; the treasurer splits one payer's payment over several plots when entering it.